

Personal Data Privacy in Software Development Processes: A Practitioner's Point of View

Vinicius C. Andrade
Department of Computer Science
Federal Technology University - Paraná
Ponta Grossa, Brazil
vcandrade@utfpr.edu.br

Cinthia O. A. Freitas
Programa de Pós-Graduação em Direito (PPGD)
Pontifical Catholic University of Paraná (PUCPR)
Curitiba, Brazil
cinthia.freitas@pucpr.br

Sheila Reinehr
Programa de Pós-Graduação em Informática (PPGIA)
Pontifical Catholic University of Paraná (PUCPR)
Curitiba, Brazil
sheila.reinehr@pucpr.br

Andreia Malucelli
Programa de Pós-Graduação em Informática (PPGIA)
Pontifical Catholic University of Paraná (PUCPR)
Curitiba, Brazil
malu@ppgia.pucpr.br

Abstract—Ensuring customer preferences and needs are met while maintaining legal compliance has become a significant concern for software development organizations. Laws and regulations such as the LGPD in Brazil and the GDPR in the European Union emphasize incorporating personal data privacy rights from the initial stages of system development, extending throughout the entire data lifecycle. However, recent studies indicate that many companies still neglect data privacy in their development processes. Therefore, this research investigates how organizations integrate personal data privacy into their software development processes. A multiple case study was conducted involving five organizations of varying sizes and domains, and qualitative analysis techniques were applied to summarize the findings. The study identified that organizations primarily address data privacy issues in the later stages of the development process. This can be attributed to the need for personal data privacy specialists within the composition of the development teams and the absence of encouragement from organizations for employees to undergo relevant training and courses focused on data privacy. These findings help organizations understand how to improve their software processes to mitigate issues related to user privacy.

Keywords—privacy, personal data protection, software development process

I. INTRODUCTION

Data subjects are increasingly concerned about which personal information is being collected, used, stored, and shared [1]. However, despite the importance of maintaining personal data privacy, companies' misuse of this information continues to occur. As an example of that, it can be cited the scandal involving the companies Facebook and Cambridge Analytica, which resulted in the collection and misuse of personal data of 87 million users in 2018 ([2], [3]) and in 2021. Another example is the case of Twitch, Amazon's streaming platform, which suffered a leak of 128 gigabytes of personal data from streamers ([4], [5]). When considering the Brazilian scenery, there was an incident of data leakage at Inter Bank in 2018, which resulted in the loss of personal information from 19,961 account holders [6]. Later, in 2021, the largest data leak ever recorded in Brazil occurred, in which 223 million persons' unique identification numbers were exposed [7]. More recently (2022), 137,285 instant payment keys (known as "PIX") containing the holders' data were released [8].

By recognizing the importance of safeguarding the privacy of data subjects, software development companies have come

to consider data privacy as a primary concern due to the requirements of data protection laws, such as the General Data Protection Regulation (GDPR) from the European Union [9], and the Brazilian General Data Protection Law (LGPD) [10].

To ensure legal compliance and the integrity of personal data privacy, Cavoukian [11] and Kalloniatis [12] mention that privacy requirements must be considered during all stages of the software development process. However, the lack of software development processes that preserve personal data privacy in all activities, combined with the lack of understanding or knowledge about data protection on the part of system developers, might result in low-quality software products that are susceptible to problems related to data privacy [13].

From this scenario, which strongly impacts the entire software development cycle and the quality of the final product, there is an interest in carrying out case studies with organizations from different sectors of activity to understand how personal data privacy has been integrated into the software development process. Thus, the following Research Questions (RQ) were defined:

- (RQ-1) How is personal data privacy being integrated into software development?
- (RQ-2) What are the difficulties associated with this integration?

To answer the research questions, ten semi-structured interviews were carried out with software development professionals from five organizations in different areas of activity, two professionals from each organization. The interviews were transcribed and analyzed using qualitative analysis procedures [14].

This work is organized as follows: Section 2 presents a background on related concepts. Section 3 presents related works. Section 4 describes the research method. Section 5 presents the results. Section 6 discusses the relevance of the results. Section 7 presents the threats to validity, and Section 8 concludes the paper with final considerations.

II. BACKGROUND

According to [15], privacy can be defined as "the right to be let alone". However, when considering the globalization that has occurred in recent decades and the way we communicate, [16] establishes that the data subject has the

right to determine when, how, and for what purpose their personal information is shared with others. This concept is similar to that of [17], who mentions that privacy can be defined as the individual's right to access and control their personal data in relation to collection, use, and transfer using communication.

Although the concepts of privacy and information security are interconnected, they are distinct. While data security aims to guarantee the integrity, confidentiality, and availability of data and prevent incidents such as data breaches, data privacy seeks to ensure that personal information is used appropriately, transparently, and in accordance with the preferences and rights of data subjects [18].

The privacy of the data subject can be guaranteed through the use of Privacy by Design (PbD) [11], which aims to integrate privacy and data protection from the early stages of system design, extending to its design, encompassing organizational procedures, network architectures, and improved governance systems. PbD encompasses seven fundamental principles that provide a comprehensive framework for proactively and efficiently integrating privacy requirements at the earliest stages of the design process.

III. RELATED WORK

This section presents studies that provide an understanding of how organizations and software developers have dealt with personal data privacy. For [19], some common barriers impact the implementation of privacy in the software development process, such as privacy culture, internal prioritization tensions, limited tool support, non-objective evaluation metrics, and technical complexity. Research by [20] investigated how senior engineers comply with personal data privacy regulations and concluded that there is a lack of responsibility, control, autonomy, and frustrations with software engineers' interactions in the legal area.

In the same sense, the studies by [21] and [22] found that information technology professionals do not have the necessary knowledge to implement privacy principles in accordance with current laws. As a suggestion, the need to provide formal education on personal data privacy practices to software developers is mentioned [22].

In a survey conducted with 253 software engineer professionals from the IT industry [23], the results demonstrated that appropriate incentives and a suitable organizational and technical infrastructure are fundamental to the successful implementing of data privacy requirements in software development projects.

The literature explains several challenges in understanding and implementing personal data privacy in organizations. Although the related studies investigate the problems faced by software developers, the works do not address how personal data privacy is inserted in the companies' development process, whether there are qualified and specialized professionals in the composition of the development teams, what tools are used to help employees to secure and safeguard the users' personal data and whether the top management of organizations supports the creation and implementation of privacy requirements, even if this negatively impacts the development time of the functional requirements of the software product. Thus, the contribution of the research presented in this article is to understand how organizations

integrate personal data privacy in their software development processes and the difficulties inherent in this process.

IV. RESEARCH METHOD

In order to understand how personal data privacy is being integrated into the software development process, the case study method was chosen, with data collection through ten semi-structured interviews with members of software development teams from five organizations. As the research covers more than one software development company, it will be a multiple case study, adapting the method proposed by [24], shown in Figure 1.

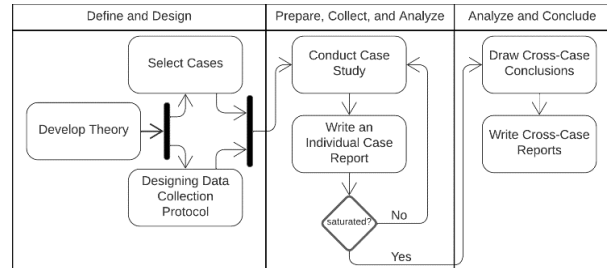


Fig. 1. Research method steps

The Define and Design step involves Develop Theory, Select Cases, and Designing Data Collection Protocol. In the Prepare, Collect, and Analyze stage, the case study is carried out, with the activities: Conduct Case Study and Write an Individual Case Report. According to [25], this step can be repeated iteratively until all possibilities are exhausted and new case studies do not collaborate in the evolution of the research. Finally, the Analyze and Conclude step comprises the activities: Draw Cross-Case Conclusions and Write Cross-Case Reports.

To conduct the research, based on the above-cited data privacy literature, we established two propositions:

- Proposition 1: Software development companies do not systematically integrate personal data privacy requirements into their development processes.
- Proposition 2: Software development companies face difficulties reformulating their processes in search of compliance with laws and regulations.

To investigate these propositions, we established five Analysis Points (AP):

- AP-01: Existence of systematized processes that integrate personal data privacy in software development;
- AP-02: Existence of specialists in personal data privacy in the composition of software development teams;
- AP-03: Existence of knowledge in the area of personal data privacy by the technical team of the organization;
- AP-04: Existence of tools that assist in the integration of personal data privacy into the development of software products;
- AP-05: Existence of factors that make it challenging to prioritize personal data privacy issues during software development.

A. Recruitment and Procedures

Through the corporate social media LinkedIn, we sent the invitation directly to the professionals identified as the study sample who should be working or managing software development squads in organizations.

Ten professionals from five organizations replied, saying they agreed to participate in the survey. The documentation needed to carry out the research, such as a letter of introduction, a data use commitment form, an informed consent form, and a letter of authorization from the institution, were sent by email, which was read and signed by the

professional, agreeing to take part in the study. In this same email, the participant was asked to indicate the best time for the interview, which should not exceed 60 minutes. The interviews were conducted virtually.

Table I gives an overview of the participants regarding their professional roles, years of work at their current company, and years of experience in the area. There is a variation in the roles and years of experience of the participating employees, which makes it possible to investigate how personal data privacy is being dealt with in different contexts and domains of software development.

TABLE I. OVERVIEW OF CASE STUDY PARTICIPANTS

Company	Domain	Number of Employees	Employees	Role	Years of Company	Years of Experience
A	Retail	1,000 – 9,999	E1	Digital Product Manager	4	8
			E2	Integration Analyst	3	10
B	Financial	1,000 – 9,999	E3	Senior Software Engineer	5	12
			E4	Quality Analyst	3	12
C	Hardware Solutions	+10,000	E5	Senior Software Engineer	2	12
			E6	Information Security Analyst	4	15
D	Software Factory	100 – 999	E7	Team Lead Software Engineer	14	23
			E8	Software Quality Coordinator	16	17
E	Financial	100 – 999	E9	Solutions Architect Specialist	3	22
			E10	Senior Information Security Analyst	2	18

For data collection, interviews were conducted based on a semi-structured script (see Table II) with questions related to the Propositions and the APs.

TABLE II. ANALYSIS POINTS DESCRIPTION

Analysis Point 1	Proposition 1
- Does the organization have an established process for software development? - Are there specific processes used in the organization for integrating personal data privacy into projects? - To what extent does the organization consider personal data privacy throughout the data lifecycle?	
Analysis Point 2	Proposition 1
- How are personal data privacy experts involved in software development projects? - Do personal data privacy specialists work on the same software product development teams, or are they allocated separately on demand?	
Analysis Point 3	Proposition 1
- Is there any initiative in the organization to promote knowledge of personal data privacy? - Has the technical team been trained to be knowledgeable in personal data privacy? - Does the organization have a policy that encourages training in personal data privacy?	
Analysis Point 4	Proposition 1
- Does the development team use any tool to help integrate personal data privacy into software product development? - How do these tools help the development of the software product?	
Analysis Point 5	Proposition 2
- How does the organization's senior management support creating and implementing policies that promote the integration of personal data privacy into the software development process? - Is delivering working software in a short time prioritized over personal data privacy? - Is there a specific phase in the organization's development process for surveying and recognizing all users who will use the system?	

B. Data Analysis

We transcribed the interviews and coded the materials using qualitative analysis procedures [14]. For this study, we used open coding [26]. Using the Atlas.ti version 9 tool, we interpreted the data and labeled it based on its properties and context. This way, two or more data related to the same subject were marked with the same code, even in different interviews.

The first interaction involved two researchers coding interviews. The data obtained was divided into segments from which initial codes were created. The coding was then analyzed, and the result was used as a knowledge base for the coding of the other interviews. Subsequently, the two researchers began coding the interviews separately, with a collective review process at the end of the coding for each organization.

According to [26], axial and selective coding represents the second coding cycle. To carry out axial coding, we analyzed the codes created to identify existing similarities so that they could be aggregated according to context, causality, and consequences. Once the similarities had been identified, the codes were grouped into categories.

Selective coding was carried out by identifying the relationships between the categories created previously. This made it possible to create broader categories such as Software Development Process; Software Development Teams; Technical Team Knowledge; and Organizational Policies. Figure 2 presents the network generated in the selective coding phase containing all the practices identified.

V. RESULTS

The cases of each company researched (Table I) are discussed below. Due to space limitations, not all quotes can be placed to support the findings.

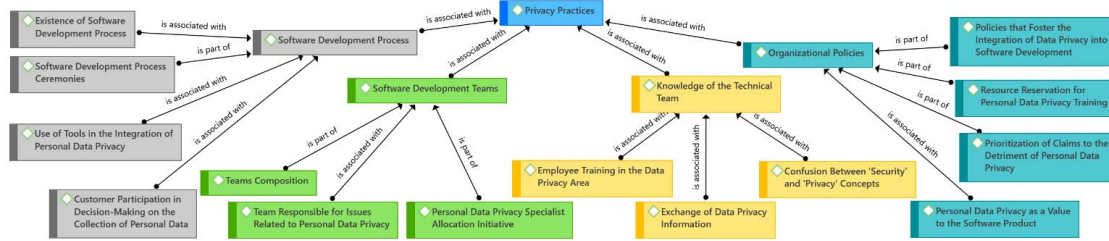


Fig. 2. Network generated in the selective coding phase

A. Company A

The organization's main activity focuses on the distribution and trade of products. Recently, the organization's managers defined the Scrum model as the basis for the development and maintenance process of software products. As mentioned by employee E1: *"We use Scrum, but it is not rigid at all. So, there is variation in time between teams. Here, the teams have the autonomy to modify a pre-existing process"*. However, we did not find any stage responsible for integrating personal data privacy into the organization's software development process. Therefore, **Analysis Point 1 was not found in the organization.**

Regarding Analysis Point 2, we found that the development teams are made up of multidisciplinary profiles. However, there is no specialist in personal data privacy in these teams, as mentioned by E2: *"The teams have collaborators from different areas. I have people responsible for the user interface, for development, for testing. But we have no initiative to put privacy people on the teams"*. Therefore, **Analysis Point 2 was not found in the organization.**

In relation to Analysis Point 3, we identified that when new employees are hired, they must take various courses, including personal data privacy and the General Data Protection Law (LGPD) [10]. However, the courses are not intended to train an expert in personal data privacy, as mentioned by E2: *"When a new employee is hired, there is a privacy course they must take. There are several courses there, on LGPD, on privacy, but they are superficial courses"*. As a result, **Analysis Point 3 was partially found in the organization.**

Regarding Analysis Point 4, we found that the organization does not use tools to help the development team detect vulnerabilities and implement requirements related to personal data privacy. The organization's concern with issues related to personal data privacy is still very recent. As mentioned by E1: *"In terms of privacy, we don't have any tools today. We are starting to take care of quality and vulnerability issues. But today, specifically personal data privacy, not yet"*. Therefore, **Analysis Point 4 was not found in the organization.**

As for Analysis Point 5, we observed that development teams have the autonomy to prioritize pending activities as long as it does not contradict the LGPD. In this case, when there are risks related to personal data privacy, the software product is not implemented until the risks are fully resolved, as mentioned by E1: *"As the development teams have autonomy, there is a guideline that establishes what actions that violate the LGPD cannot occur"*. In this way, **Analysis Point 5 was not found in the organization.**

For Proposition 1, four analysis points were related (AP-1, AP-2, AP-3, and AP-4). We found that the organization does not have an activity aimed at personal data privacy in its software development process. We found that there is no specialist in data privacy composing the development teams and that employees do not use tools to help promote personal data privacy in the development environment. Therefore, **Proposition 1 was considered true.**

On the other hand, we found that with the support of top management, the organization is restructuring and hiring trained professionals to solve problems related to personal data privacy. In this way, **Proposition 2 was not considered true.**

B. Company B

Organization B is a company in the financial sector that develops innovative solutions for this segment. The organization uses the Scrum model to develop and maintain its software products, including all rituals. However, we did not find systematic steps and/or activities for identifying and solving personal data privacy issues. According to E3: *"Professionals are very mature in identifying issues related to personal data privacy. When there is any doubt, the legal team helps in understanding the legal complications"*. Therefore, **Analysis Point 1 was not found in the organization.**

Regarding Analysis Point 2, we found that the organization's development teams are made up of employees with multidisciplinary profiles. Team members know all areas necessary for product development related to technical details. However, no professional is dedicated exclusively to personal data privacy, as reported by E4: *"No one is specifically allocated to privacy because this is in the development flow. Whoever is coding needs to keep this in mind not to break any laws"*. Therefore, **Analysis Point 2 was not found in the organization.**

We found that the organization encourages and invests in updating its employees through courses and training in several areas. However, due to the high demand for the products, employees choose to take courses related to the languages and technologies used in software development. As mentioned by E3: *"The organization encourages you to seek knowledge in general with access to platforms with a data privacy course. But honestly, I think it's unlikely that anyone will study courses related to privacy because when you need to prioritize between studying one thing and another, I don't know if that would be people's priority"*. Thus, **Analysis Point 3 was partially found in the organization.**

Concerning Analysis Point 4, the organization is concerned with issues related to information security. However, the same concern of the company with issues related to personal data privacy was not verified. E4 reported:

"We used SonarQube, some other solutions to get code entropy, security, token, and everything else. But a proper scan looking for the word CPF, email, things like that, I don't remember". As a result, **Analysis Point 4 was not found in the organization.**

About Analysis Point 5, the organization's top management agrees that issues related to personal data privacy are essential to the final product and the company's image before its customers. Each employee is responsible for prioritizing demands considering the organization's business strategies. However, despite the high demand for the software product, without the minimum requirements of personal data privacy and information security, the software product is not delivered, as reported by E4: *"What happens a lot is simplifying the MVP [Minimum Viable Product] not to need this personal data and launch a simpler functionality so as not to contradict the security area".* In this way, **Analysis Point 5 was partially found in the organization.**

We verified that the organization uses the Scrum process model to develop its products. However, systematic activities aimed at identifying problems and proposing solutions to issues related to personal data privacy are not established. In addition, we found that the teams are made up of professionals with multidisciplinary profiles, there are no specialists in personal data privacy, and tools that help integrate personal data privacy into the development of the software product are not used. Therefore, **Proposition 1 was considered true.**

On the other hand, we found that the organization has the resources to invest in training the technical staff. However, there was a lack of incentive from these budgets for the area of personal data privacy. Thus, **Proposition 2 was considered partially true.**

C. Company C

Organization C's main activity is the development of both hardware and software, in addition to providing technical assistance to its customers. The organization has a well-defined process based on Scrum and Kanban for software development and maintenance. However, in the organization's development process, there is no activity responsible for identifying problems and solutions related to personal data privacy. Nevertheless, annually, employees analyze the fields in the database to classify them according to the level of access, and this is due to possible vulnerabilities generated from changes made to the database during the year. As reported by E6: *"Once a year, we have to analyze all fields in the databases. I must classify 'restricted', 'public', or 'internal'. And if it is restricted, I must say whether it is encrypted".* In this way, **Analysis Point 1 was partially found in the organization.**

Development teams are made up of members with multidisciplinary skills. These employees do not need a deep understanding of personal data privacy and information security issues, as the organization has a specific team responsible for receiving the software developed to test them for vulnerabilities in terms of information security and personal data privacy, as mentioned by E5: *"There is a separate security team that generates the vulnerability report".* Therefore, **Analysis Point 2 was not found in the organization.**

Although the development team is not made up of specialists in specific areas, the organization provides several courses annually to encourage updating its employees. According to E5: *"We have to take courses, including on data*

privacy. New courses are made available every year, and we have to take a minimum number of course hours per year". Thus, **Analysis Point 3 was found in the organization.**

In Analysis Point 4, we identified the organization's concern with issues related to information security. The company has recently invested in hiring specialists and tools to become a reference. However, when it comes to personal data privacy, the development team does not have tools that help them detect possible vulnerabilities. As reported by E5: *"We have a guide. As a developer, I say whether the field is important or not. No tool helps me or automates this process. It is a manual analysis done in conjunction with the business department".* As a result, **Analysis Point 4 was not found in the organization.**

The concern of the organization's top management focuses on remaining in compliance with current legislation. Therefore, software development teams must follow established policies to respect issues related to this topic. In cases where a product does not meet minimum privacy requirements, the team responsible for the system must resolve the issue with top priority. As reported by E6: *"The team that takes care of personal data determines what should be done. If your system does not meet what is required by a certain date, then this requirement is added to a red list and given zero priority".* Therefore, **Analysis Point 5 was not found in the organization.**

Concerning propositions, we found that the organization uses the Scrum and Kanban models as agile development processes. However, we did not find the integration of activities related to personal data privacy into the company's process model nor the use of tools that help employees identify vulnerabilities related to personal data privacy. In addition, there are no personal data privacy specialists working on the development teams. Thus, **Proposition 1 was considered true.**

However, we found that complying with legislation is a priority for the organization's top management and that favoring the delivery of functional software over non-functional requirements, such as data privacy, does not occur in the company. Therefore, **Proposition 2 was considered not true.**

D. Company D

Organization D is a company focused on software development, certified by ISO 9001:2015. For product development and maintenance, the organization has a hybrid development process. However, no activity in the development process integrates issues related to personal data privacy, according to E8: *"There is a data privacy policy, but there is no defined process. Nor is the privacy policy integrated into the development process".* In this way, **Analysis Point 1 was not found in the organization.**

The development teams are made up of collaborators with different profiles and do not have specialists in data privacy nor an initiative to allocate professionals with this profile in the development teams, as reported by E7: *"The teams do not have privacy specialists because this activity is outsourced".* Therefore, **Analysis Point 2 was not found in the organization.**

With regard to Analysis Point 3, an outsourced company performs the activity of verifying whether these products comply with current legislation. For this reason, the organization's technical staff does not have in-depth

knowledge of personal data privacy, and the organization has no initiative to train specialists in the area. As quoted by E8: *"The material is very succinct and does not provide information at the level of training someone. The information is very shallow because the objective is not to train specialists. It is just to bring a little knowledge"*. Thus, **Analysis Point 3 was not found in the organization.**

About Analysis Point 4, the organization is concerned with identifying coding vulnerabilities. For this, the Sonar tool is used, which performs static analysis of the source code to identify deprecated commands and basic cryptography, among other vulnerabilities. However, we did not find the use of specific tools for privacy and protection of personal data. As reported by E8: *"For information security, we have Sonar. For data privacy, we don't"*. As a result, **Analysis Point 4 was not found in the organization.**

Although the organization's top management is not interested in encouraging the hiring and training of professionals specialized in personal data privacy, the directors understand the need and importance of including privacy requirements in their products to be legally compliant. This translates into investments in contracting specialized companies, as mentioned by E8: *"Given by the investment we have in this area for hiring a third-party company and the cost that this generates for us, there is indeed great interest on our part. But we are not interested in bringing this know-how internally"*. Therefore, **Analysis Point 5 was found in the organization.**

Regarding the propositions, we did not find in the software development process used by the organization activities related to identifying and resolving privacy problems and protecting personal data. The development teams do not have a data privacy specialist in their composition, and they do not use tools that help them integrate privacy requirements into software development. Thus, **Proposition 1 was considered true.**

In addition, there is concern from the organization's top management to comply with the law. Therefore, there are investments in hiring third-party companies responsible for identifying and reporting problems related to personal data privacy. However, investments to train internal collaborators in this matter are not prioritized. Therefore, **Proposition 2 was considered true.**

E. Company E

Organization E is a company in the financial sector. For the development and maintenance of its systems, the organization has agile teams that use the Scrum or Kanban model in managing their projects. However, no activity integrated into the agile development process is responsible for identifying and correcting requirements related to personal data privacy, as reported by E9: *"We are trying to check data privacy requirements early in the development process, but this is not yet in operation"*. Therefore, **Analysis Point 1 was partially found in the organization.**

The teams are formed by professionals specialized in different areas. However, there are no specialists in personal data privacy in the development teams' composition, as quoted by E9: *"The teams do not have a privacy specialist. This role is often shared with the PO or the architect"*. Therefore, **Analysis Point 2 was not found in the organization.**

The organization provides courses in several areas through a digital platform. However, it does not aim to train specialist

professionals in certain areas. When employees have any questions regarding data privacy, the legal department is consulted, as mentioned by E10: *"Depending on the team, they request more information. They schedule meetings with me or with my co-worker to understand what the interpretation of the law is in the face of a fact that they want to change in a current process"*. With this, **Analysis Point 3 was partially found in the organization.**

Regarding Analysis Point 4, the organization uses tools that help host and access stored data, as mentioned by E9: *"Our database is in the cloud, in Microsoft Azure. Databases on Azure have a default configuration that works for LGPD and GDPR, and you can define in a data structure which information is sensitive and which is not. And, from this, you define who should or should not view the information"*. In this way, **Analysis Point 4 was found in the organization.**

The organization hired specialized consultants and professionals to assist in adapting to the LGPD. These professionals work at the end of the development process. As mentioned by E9: *"The systems are submitted to a risk management committee. This committee verifies whether it is a high, medium, or low risk and whether it makes sense to postpone the implementation of the functionality"*. Therefore, **Analysis Point 5 was found in the organization.**

Regarding propositions, the organization uses the Scrum and Kanban models in its development processes. However, concerns about personal data privacy issues occur at a late stage, only after the delivery of software products that are audited by professionals specializing in personal data privacy and by the organization's legal department, who act separately from the teams of development. On the other hand, employees use tools that help them safeguard their customers' data privacy. Thus, **Proposition 1 was considered true.**

Although top management recognizes the importance of addressing issues related to personal data privacy in its products, there is no policy to integrate data privacy into the software process. Currently, there are only two data privacy specialists who advise the organization's sixteen development teams, which generates high demand for these professionals and may result in prioritizing the delivery of products within the established deadline to the detriment of the privacy requirements of personal data. Therefore, **Proposition 2 was considered true.**

VI. DISCUSSION

In the midst of several cases of personal data leaks, which negatively affect companies, such as image and reputation crises, as well as financial losses, laws, and regulations have been revised in several countries, such as the LGPD and the GDPR, and software development companies are adapting to the laws and wishes of their users, who are increasingly concerned about how their personal information is used by the services they use and, above all, adopt a more cautious behavior when sharing personal data.

Table III presents a comparative summary of the analysis points between the companies interviewed. To summarize the results, for each analysis point and proposition, we use the following formats: (●) is found in the organization, (◐) is partially found in the organization, and (○) is not found in the organization.

Regarding analysis point 1, in no organization was it possible to verify the full integration of personal data privacy into the software process. Only the C and E organizations

TABLE III. OVERVIEW OF ANALYSIS POINTS RESULT.

Company	Analysis Points				
	AP-01	AP-02	AP-03	AP-04	AP-05
A	○	○	●	○	○
B	○	○	●	○	●
C	●	○	●	○	○
D	○	○	○	○	●
E	●	○	●	●	●

have specific care for personal data privacy. At Company C, there is a policy that annually reviews what has been developed to identify and resolve vulnerabilities related to personal data privacy. At Company E, a committee is responsible for verifying the legal compliance of the product developed. At this analysis point, it would be important for organizations to integrate privacy and personal data protection concerns throughout the software development lifecycle, not just in the later stages of implementation.

For organizations to be concerned with data privacy issues from the initial stages of the project, teams should integrate professionals with in-depth knowledge of privacy and personal data protection to solve problems during the product development cycle and not only after a review by another team.

Although the teams do not have a dedicated professional with expertise in personal data privacy, it was found that the organizations offer training courses on this topic for their employees. In some organizations, professionals must take these courses when they are hired. In other companies, professionals can take courses at specific times to update and improve their skills. However, it has been found that these are introductory courses on personal data privacy, LGPD [10], and vulnerabilities, among other topics, and are not aimed at training specialists in the area. In this scenario, we suggest that at least one team member take periodic privacy and data protection courses. In this way, each team could have a specialist who could disseminate the knowledge to the other members of their squad.

The use of tools that help integrate data privacy into software development was found only in organization D, which uses software to comply with the LGPD [10] and the GDPR [9] and a second tool to provide service to its customers, giving them transparency and autonomy over their stored personal data. Other companies do not concern themselves with data privacy issues or carry out vulnerability checking processes manually. It is important to note that employees use the term “security” to refer to “privacy”, without distinguishing between the terms. At this analysis point, various software was mentioned by employees. However, it was specifically about information security software.

Finally, analysis point 5 was not found in two organizations, A and C. Although these organizations have issues related to data privacy, they have a policy of meeting the requirements of the legislation, including personal data privacy. Additionally, organizations A and C are restructuring their teams so that data privacy is increasingly integrated into the development process. Organizations D and E have specific teams to analyze the legal compliance of the product developed. Therefore, top management does not intend to integrate privacy and personal data protection during the product development cycle. Table IV summarizes the results of the propositions defined.

TABLE IV. OVERVIEW OF PROPOSITIONS ANALYSIS RESULT.

Propositions	Company					Final Result
	A	B	C	D	E	
P-01	●	●	●	●	●	●
P-02	○	●	○	●	●	●

After analyzing all organizations, we found evidence that proposition 1 is true, as none of the organizations interviewed integrates personal data privacy requirements into software development processes, and only one uses tools that help employees adapt to the legal compliance of their software products. Although the organizations offer training courses to their employees, the content is not enough and is not intended to train specialists. As a result, there are no specific professionals to deal with data privacy issues in the composition of development teams.

Proposition P2 is partially true, as we found no evidence to prove that it is difficult for the organizations interviewed to reformulate their processes in order to comply with laws and regulations. In most cases, top management agrees that concerns about personal data privacy are important for the organization, the company's image, and the quality of the final product. However, in some organizations, employees are not motivated to take specific courses and training in personal data privacy.

In general, we observed that the companies interviewed, regardless of their market segment, are concerned about complying with current laws and regulations. However, integrating personal data privacy into their process models is still incipient. This can be seen in the absence of data privacy specialists on the development teams. Reviews of the codes generated take place at later stages of the software development, either by an internal team or by a third-party company. In cases where an internal team carries out the review, we found that the team serves all development teams, which overwhelms employees and, in some cases, causes delays in the delivery of software products.

We found that the concept of “personal data privacy” is not given the same importance by organizations, and their employees usually treat it as “information security”. This was observed at various times during the interviews, without distinguishing between the terms and, in some cases, mentioning security techniques and tools to mitigate data privacy issues. We also observed that employees are concerned about the security of user data, but do not show the same concern for the privacy of the user's personal data.

VII. THREATS TO VALIDITY

In this work, a threat to the validity of the construct arises from the use of interviews to identify how organizations integrate personal data privacy into their development processes and the difficulties of this integration. This is because there may be flaws, prejudices, or inaccurate articulations in the narratives of each participant. For these reasons, this study was designed to approach several organizations with more than one interview. Thus, a version reported by a participant complements the others.

The threat to external validity is related to the generalization of the results. Due to its qualitative nature, the number of participants and companies is restricted, and it is not possible to guarantee the generalizability of the results. However, it is important to highlight that the findings

presented in this study are similar to those found in other studies ([19], [20], [22], [23]).

VIII. CONCLUSIONS

We interviewed ten software development professionals with experience ranging from 8 to 23 years in five organizations of varying sizes, employing from 100 to over 10,000 people each. The organizations operate in a variety of sectors, including retail, financial services, software factory, and hardware development.

Although the organizations express concerns about legal compliance and software quality due to the possible risks to their reputation from data breaches, the study reveals that specific teams or third parties often address data privacy at a later stage. This contradicts laws like LGPD and GDPR, which emphasize addressing personal data privacy requirements throughout the product development cycle.

We also observed that the software development teams of the organizations interviewed do not have a data privacy specialist. In addition, they do not encourage their employees to take in-depth courses and training on the subject, causing a lack of knowledge. Furthermore, the interviewees do not distinguish between the terms “privacy” and “security”. When asked, they reported that privacy and security challenges are treated the same way in the organization.

As prospects for future work, we intend to replicate the study in organizations of different sizes, with headquarters in other countries and other domains, to verify how issues related to personal data privacy are being integrated into the software development process. In addition, we are working on a proposing a software development process that integrates personal data privacy in order to help organizations comply with legislation.

REFERENCES

- [1] S. É. R. Ferrão, A. P. Carvalho, E. D. Canedo, A. P. B. Mota, P. H. T. Costa, and A. J. Cerqueira, “Diagnostic of Data Processing by Brazilian Organizations - A Low Compliance Issue,” *Information*, vol. 12, no. 4, pp. 1–30, 2021.
- [2] M. Rosenberg, “Cambridge Analytica and Facebook: The Scandal and the Fallout So Far,” *The New York Times*, 2018. <https://www.nytimes.com/2018/04/04/us/politics/cambridge-analytica-scandal-fallout.html> (accessed Mar. 10, 2021).
- [3] C. 4 N. I. Team, “Revealed: Cambridge Analytica data on thousands of Facebook users still not deleted,” *Channel 4 News*, 2018. <https://www.channel4.com/news/revealed-cambridge-analytica-data-on-thousands-of-facebook-users-still-not-deleted> (accessed Mar. 10, 2021).
- [4] K. Browning, “A ‘potentially disastrous’ data breach hits Twitch, the livestreaming site,” *The New York Times*, 2021. <https://www.nytimes.com/2021/10/06/technology/twitch-data-breach.html> (accessed Jun. 07, 2023).
- [5] J. Tidy and D. Molloy, “Twitch confirms massive data breach,” *BBC*, 2021. <https://www.bbc.com/news/technology-58817658> (accessed Jun. 07, 2023).
- [6] Redação Veja, “Banco Inter vai pagar R\$ 1,5 milhão por vazamento de dados de clientes,” *Veja*, 2018. <https://veja.abril.com.br/economia/banco-inter-vai-pagar-r-15-milhao-por-vazamento-de-dados-de-clientes/> (accessed May 24, 2021).
- [7] A. Rohr, “Megavazamentos de dados expõem informações de 223 milhões de números de CPF,” *Globo Comunicação e Participações S.A.*, 2021. <https://g1.globo.com/economia/tecnologia/blog/altieres-rohr/post/2021/01/25/vazamentos-de-dados-expoem-informacoes-de-223-milhoes-de-numeros-de-cpf.ghtml> (accessed May 24, 2021).
- [8] J. P. Malar, “Banco Central anuncia vazamento de dados ligados a mais de 130 mil chaves Pix,” *CNN Brasil Business*, 2022. <https://www.cnnbrasil.com.br/economia/banco-central-anuncia-vazamento-de-dados-ligados-a-mais-de-130-mil-chaves-pix/> (accessed Apr. 11, 2023).
- [9] EU, “Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46,” *Off. J. Eur. Union*, vol. 59, no. 1–88, p. 294, 2016.
- [10] BRASIL, “Lei Geral de Proteção de Dados Pessoais (LGPD),” 2018. http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/113709.htm (accessed Oct. 09, 2023).
- [11] A. Cavoukian, “Privacy by Design - The 7 foundational principles - Implementation and mapping of fair information practices,” *Inf. Priv. Comm. Ontario, Canada*, p. 5, 2009, [Online]. Available: https://www.iab.org/wp-content/IAB-uploads/2011/03/fred_carter.pdf%5Cnwww.privacybydesign.ca.
- [12] C. Kalloniatis, E. Kavakli, and S. Gritzalis, “Methods for Designing Privacy Aware Information Systems: A review,” in *13th Panhellenic Conference on Informatics*, 2009, pp. 185–194, doi: 10.1109/PCI.2009.45.
- [13] V. C. Andrade, R. D. Gomes, S. Reinehr, C. O. D. A. Freitas, and A. Malucelli, “Privacy by Design and Software Engineering: a systematic literature review,” in *Proceedings of the XXI Brazilian Symposium on Software Quality (SBQS)*, 2022, vol. 1, no. 1, pp. 1–10, doi: 10.1145/3571473.3571480.
- [14] A. Strauss and J. Corbin, “Basics of qualitative research techniques,” Thousand oaks, CA Sage Publ., 1998.
- [15] S. D. Warren and L. D. Brandeis, “Right to privacy,” *Harv. L. Rev.*, vol. 4, p. 193, 1890.
- [16] S. Spiekermann and L. F. Cranor, “Engineering privacy,” *IEEE Trans. Softw. Eng.*, vol. 35, no. 1, pp. 67–82, 2008.
- [17] J. E. Boritz, G. N. Won, and R. P. Sundarraj, “Internet privacy in E-commerce: Framework, review, and opportunities for future research,” *Proc. Annu. Hawaii Int. Conf. Syst. Sci.*, no. 2, pp. 1–10, 2008, doi: 10.1109/HICSS.2008.215.
- [18] T. McGill and N. Thompson, “Exploring potential gender differences in information security and privacy,” *Inf. Comput. Secur.*, vol. 29, no. 5, pp. 850–865, 2021.
- [19] M. Tahaei, A. Frik, and K. Vaniea, “Privacy champions in software teams: Understanding their motivations, strategies, and challenges,” *Conf. Hum. Factors Comput. Syst. - Proc.*, 2021, doi: 10.1145/3411764.3445768.
- [20] K. Bednar, S. Spiekermann, and M. Langheinrich, “Engineering Privacy by Design: Are engineers ready to live up to the challenge?,” *Inf. Soc.*, vol. 35, no. 3, pp. 122–142, 2019, doi: 10.1080/01972243.2019.1583296.
- [21] E. D. Canedo, A. T. S. Calazans, E. T. S. Masson, P. H. T. Costa, and F. Lima, “Perceptions of ICT Practitioners Regarding Software Privacy,” *Entropy*, vol. 22, no. 4, p. 429, 2020, doi: 10.3390/E22040429.
- [22] A. Senarath and N. A. G. G. Arachchilage, “Why developers cannot embed privacy into software systems?: An empirical investigation,” in *arXiv*, 2018, doi: 10.1145/3210459.3210484.
- [23] F. Bu, N. Wang, B. Jiang, and H. Liang, “‘Privacy by Design’ implementation: Information system engineers’ perspective,” *Int. J. Inf. Manage.*, vol. 53, no. July 2019, p. 102124, 2020, doi: 10.1016/j.ijinfomgt.2020.102124.
- [24] R. K. Yin, *Case Study Research and Applications*, 6th ed. Sage Publications, 2018.
- [25] A. Rainer and T. Hall, “Key success factors for implementing software process improvement: A maturity-based analysis,” *J. Syst. Softw.*, vol. 62, no. 2, pp. 71–84, 2002, doi: 10.1016/S0164-1212(01)00122-4.
- [26] J. Saldaña, *The coding manual for qualitative researchers*, 2 ed. SAGE Publications Limited, 2013.